BREACHSIEVE - Vulnerability Assessment Report

Target: http://localhost:3000 | Date: 2026-10-17 15:54:03 UTC

Risk Score	Critical	High	Medium	Low	False Positives	Novel Patterns
2.0	0	0	0	6	0	3

Scope & Authorization Record

Target URL	http://localhost:3000
Scan Mode	ACTIVE (Active Confirmed: 1)
Authorization Status	CONFIRMED - Explicit authorization granted by operator
Authorized At	2026-10-17T15:53:43.698004+00:00
In-Scope Rules	localhost:3000 127.0.0.1
Out-of-Scope Rules	None

Confirmed Vulnerability Findings (6)

[BS-FIND-001] Missing Anti-clickjacking Header - **Low (CVSS: 1.7)**

CWE: CWE-1021 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000
Description: The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Gemini AI Verdict: [CONFIRMED] Confirmed: HTTP response headers omit both 'X-Frame-Options' and CSP 'frame-ancestors'. The target page can be rendered inside an unauthorized <iframe> layer.
Remediation: Configure 'Content-Security-Policy: frame-ancestors self' and 'X-Frame-Options: SAMEORIGIN'.

[BS-FIND-002] X-Content-Type-Options Header Missing - **Low (CVSS: 2.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: http://localhost:3000/favicon.svg
Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Gemini AI Verdict: [CONFIRMED] Confirmed: Missing 'X-Content-Type-Options: nosniff' header enables MIME sniffing vulnerabilities.
Remediation: Send 'X-Content-Type-Options: nosniff' on all text/html and script responses.

[BS-FIND-003] Content Security Policy (CSP) Header Not Set - **Low (CVSS: 2.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: http://localhost:3000
Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Gemini AI Verdict: [CONFIRMED] Confirmed: No 'Content-Security-Policy' HTTP response header is transmitted by the server.
Remediation: Deploy a strict Content-Security-Policy header.

[BS-FIND-004] Modern Web Application - **Low (CVSS: 2.1)**

CWE: CWE-16 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1082
URL: http://localhost:3000
Description: The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
Gemini AI Verdict: [CONFIRMED] Confirmed: Scanner detected active reflection of test vector quoting evidence: '<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$Refr' in response context at 'http://localhost:3000'.
Remediation: Apply parameterized inputs or contextual HTML entity encoding.

[BS-FIND-005] Information Disclosure - Suspicious Comments - **Low (CVSS: 0.4)**

CWE: CWE-615 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000/@vite/client
Description: The response appears to contain suspicious comments which may help an attacker.
Gemini AI Verdict: [CONFIRMED] Confirmed: Scanner detected active reflection of test vector quoting evidence: ' `\0`, a convention from the rollup ecosyste' in response context at 'http://localhost:3000/@vite/client'.
Remediation: Apply parameterized inputs or contextual HTML entity encoding.

[BS-FIND-006] HTTP Only Site - **Low (CVSS: 2.1)**

CWE: CWE-311 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000
Description: The site is only served under HTTP and not HTTPS.
Gemini AI Verdict: [CONFIRMED] Confirmed vulnerability based on corroborating scanner evidence: ".
Remediation: Configure your web or application server to use SSL (https).

Remediation Summary Matrix

ID	Title	Severity	Actionable Fix
BS-FIND-001	Missing Anti-clickjacking Head	Low	Configure 'Content-Security-Policy: frame-ancestors self' and 'X-Frame-Options: SAMEO
BS-FIND-002	X-Content-Type-Options Header	Low	Send 'X-Content-Type-Options: nosniff' on all text/html and script responses....
BS-FIND-003	Content Security Policy (CSP)	Low	Deploy a strict Content-Security-Policy header....
BS-FIND-004	Modern Web Application	Low	Apply parameterized inputs or contextual HTML entity encoding....
BS-FIND-005	Information Disclosure - Suspi	Low	Apply parameterized inputs or contextual HTML entity encoding....
BS-FIND-006	HTTP Only Site	Low	Configure your web or application server to use SSL (https)....

Methodology Note

This assessment was performed using automated OWASP ZAP scanning driven through its REST API, restricted to strictly verified in-scope allow-list rules. Alerts were triaged via Google Gemini API using evidence-based analysis to filter false positives and identify novel patterns. This automated assessment augments, not replaces, comprehensive manual security testing.